

AI / RAG System Compliance Questionnaire

1. Data Privacy & Protection (DPDP / GDPR)

- Do you collect personal data from users?
- Is explicit user consent obtained before data collection?
- Can users request deletion of their data?
- Is sensitive data encrypted at rest and in transit?
- Do you store data within permitted jurisdictions (data localization)?
- Is data anonymized or masked where possible?
- Do you have a privacy policy available to users?
- Is access to user data restricted based on roles?
- Do you log access to sensitive data?
- Do you regularly audit data storage practices?

2. Security & Infrastructure (ISO 27001 / OWASP)

- Are APIs secured with authentication and authorization?
- Is input validation implemented to prevent injection attacks?
- Are secrets (API keys, tokens) securely stored?
- Do you perform regular vulnerability scans?
- Is HTTPS enforced across all endpoints?
- Do you have firewall and intrusion detection systems?
- Are backups taken and tested regularly?
- Do you have role-based access control (RBAC)?
- Are logs monitored for suspicious activity?
- Is multi-factor authentication (MFA) enabled for admins?

3. AI / LLM Risk Management (OWASP LLM Top 10)

- Are prompts validated to prevent prompt injection?
- Do you filter harmful or unsafe model outputs?

- Is there a mechanism to detect hallucinations?
- Are outputs grounded using verified data sources?
- Do you restrict model access to sensitive internal data?
- Is user input sanitized before processing?
- Do you log prompts and responses for auditing?
- Are rate limits applied to prevent abuse?
- Is model behavior tested under adversarial conditions?
- Do you have fallback responses for uncertain outputs?

4. Logging & Monitoring (CERT-In / NIST)

- Do you maintain logs of all system activities?
- Are logs stored securely and retained for required duration?
- Is there a real-time monitoring system for incidents?
- Do you have an incident response plan?
- Are alerts configured for unusual behavior?
- Do you regularly review logs for anomalies?
- Is there a system for reporting security incidents?
- Are audit trails maintained for critical actions?
- Do you track system performance metrics?
- Are logs protected from unauthorized access?

5. Banking / Fintech Compliance (RBI Guidelines)

- Do you comply with RBI cybersecurity guidelines?
- Are financial transactions logged and monitored?
- Do you implement fraud detection mechanisms?
- Is user authentication strong (OTP, MFA)?
- Are payment systems secured against breaches?
- Do you follow KYC and AML requirements?
- Is data encrypted during financial transactions?
- Do you perform regular compliance audits?

- Are third-party integrations vetted for security?
- Do you maintain regulatory reporting records?

6. Governance & Risk Management (NIST / ISO)

- Do you have a defined risk management framework?
- Are risks identified and documented regularly?
- Do you conduct periodic internal audits?
- Is there a compliance officer or responsible role?
- Do you maintain documentation of policies and procedures?
- Are employees trained on security and compliance?
- Do you have business continuity and disaster recovery plans?
- Are third-party vendors assessed for compliance?
- Do you review and update policies regularly?
- Is there a mechanism for continuous improvement?